07. Feasify Backend REST API & Integration Test Report

Document ID: FEASIFY-DOC-07

Backend Framework: Express 5.2.1 on Node.js

Default Server Port: `http://localhost:10000`

Execution Date: November 11, 2026

Auditor: Backend API & Integration Testing Specialist

Status: Completed

---

1. Discovered API Endpoint Catalog

Based on AST analysis and route extraction from `feasify-backend/index.js`, the verified API surface consists of:

Endpoint Route	HTTP Method	Auth Required	Rate Limited	Function / Purpose
`/api/health`	`GET`	No	No	Backend health check and Gemini key presence
`/api/name-check`	`POST`	No	No	DTI & SEC name verification with trademark alert
`/api/name-check/status`	`GET`	No	No	Service status and cache diagnostic metadata
`/api/registration-sources`	`GET`	No	No	Official DTI BNRS and SEC eSPARC portal URLs
`/api/check-company-name`	`POST`	No	No	Legacy SEC company name verification
`/api/copyright-db`	`GET`	No	No	Full list of protected brands and school businesses
`/api/copyright-check`	`POST`	No	No	Check name/tagline against copyright database
`/api/teams/:groupId/proposals/count`	`GET`, `POST`	No	No	Verify group proposal count against 3-limit
`/api/proposals/validate-limit`	`GET`, `POST`	No	No	Alias for proposal count validation
`/api/teams/:groupId/proposals`	`POST`	No	Yes (60/min)	Server-side proposal creation with 3-limit check
`/api/proposals`	`POST`	No	Yes (60/min)	General proposal creation endpoint
`/api/proposals/:proposalId/status`	`PUT`	**Missing (Vulnerability)**	No	Update proposal status and adviser remarks

Endpoint Route	HTTP Method	Auth Required	Rate Limited	Function / Purpose
`/api/analyze`	`POST`	No	Yes (60/min)	Student 5-year financial feasibility analysis
`/api/analyze-financials`	`POST`	No	Yes (60/min)	Alias for student financial audit
`/api/analyze-proposal`	`POST`	No	Yes (60/min)	Adviser proposal rubric scoring & evaluation
`/api/evaluate-proposal`	`POST`	No	Yes (60/min)	Alias for proposal evaluation
`/api/exemplars/dynamic`	`GET`	No	No	Retrieve curated exemplar benchmarks
`/api/exemplars/evaluate-candidate`	`POST`	No	No	Ingest approved proposal into dynamic exemplar cache
`/api/audit/logs`	`GET`	**Yes (`verifyToken`)**	No	Retrieve Firestore audit trail with section filtering

2. API Contract & Schema Verification Results

2.1 Health Check (`GET /api/health`)

- **Request:** Empty
- **Response (`HTTP 200`):**

```
{
  "status": "ok",
  "timestamp": "2026-11-11T08:19:54.000Z",
  "backend": "Feasify Backend Engine",
  "geminiKeyConfigured": true
}
```

- **Result: PASSED**

2.2 Name Verification (`POST /api/name-check`)

- **Empty Query Request:** `{ "name": " ", "type": "business" }`
- **Response (`HTTP 400`):** `{ "status": "ERROR", "message": "Please enter a business or company name to check." }`
- **Result: PASSED**
- **Valid Query Request:** `{ "name": "Abella General Merchandise", "type": "business", "forceRefresh": true }`
- **Response (`HTTP 200`):**

```
{
  "provider": "DTI",
  "query": "Abella General Merchandise",
  "status": "FOUND",
  "matchType": "exact",
  "officialSource": "https://bnrs.dti.gov.ph/search?keyword=Abella%20General%20Merchandise",
  "records": [ ... ]
}
```


- **Result: PASSED**
- **Trademark Protected Query:** `{ "name": "Jollibee Food Hub", "type": "all" }`
- **Response (`HTTP 200`):** Includes `trademarkAlert: { isProtected: true, type: "Well-Known Brand / Registered Trademark", matchedBrand: "jollibee" }`
- **Result: PASSED**

2.3 Proposal Count Validation (`GET /api/teams/:groupId/proposals/count`)

- **Under Limit Request:** `groupId: "group-42"` (0 proposals)
- **Response (`HTTP 200`):** `{ "groupId": "group-42", "count": 0, "max": 3, "allowed": true, "message": "Proposals: 0 / 3" }`
- **Result: PASSED**
- **At Limit Request:** `groupId: "group-at-max"` (3 proposals)
- **Response (`HTTP 200`):** `{ "groupId": "group-at-max", "count": 3, "max": 3, "allowed": false, "message": "Maximum of 3 proposals reached." }`
- **Result: PASSED**

2.4 Server-Side Proposal Creation (`POST /api/teams/:groupId/proposals`)

- **At Limit Request:** Attempting 4th proposal when group already has 3 proposals
- **Response (`HTTP 400`):**


```
{
  "error": "Maximum of 3 proposals reached.",
  "message": "Maximum of 3 proposals reached per team. Further submissions are blocked.",
  "proposalLimitReached": true,
  "currentCount": 3,
  "maxProposals": 3
}
```


- **Result: PASSED**

2.5 Status Update Endpoint (`PUT /api/proposals/:proposalId/status`)

- **Valid Status Request:** `{ "status": "Approved", "adviserRemarks": "Excellent feasibility study." }`
- **Response (`HTTP 200`):** `{ "success": true, "proposalId": "prop_123", "status": "Approved" }`
- **Result: PASSED**
- **Invalid Status Request:** `{ "status": "INVALID_STATE" }`

- **Response (`HTTP 400`):** `{ "error": "Invalid status \"INVALID_STATE\". Supported statuses: Draft, Submitted, Under Review, Revision Required, Approved, Rejected." }`
- **Result: PASSED**
- **Authorization Verification:**
- **Defect API-01:** Missing `verifyToken` middleware on this route. An unauthenticated HTTP client can change any proposal's status to "Approved" or "Rejected" without providing a Firebase ID token.
- **Result: FAILED (Security Vulnerability Confirmed)**

2.6 Audit Logs Endpoint (`GET /api/audit/logs`)

- **Request without Token:** `GET /api/audit/logs`
- **Response (`HTTP 401`):** `{ "error": "Missing Authorization token." }`
- **Result: PASSED (Correctly Protected)**